個人情報漏えい 机上訓練 実施報告

実施結果・よくできていたこと・見つかった空白

参加者へ配布可 ／ ISMS記録 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

実施日時: 2026-10-02（金）15:00 - 16:00
形式: Slack完結型（会議を立てず、通常業務と並行）
シナリオ: 管理画面のログインレポートCSVダウンロード機能の不具合により、顧客が自分でダウンロードしたCSVに他社プロダクトのデータが混入していた（**架空の不具合です**）

この資料について

誰かの対応を評価するための資料ではありません。

今日の目的は「うまく対応できたか」を測ることではなく、**対応フローに何を書くべきかを洗い出すこと**でした。見つかった空白は、ルールが無かったことによるものです。
個人の判断の問題ではありません。

そのため、**うまくいった動きは名前を挙げて記録し、空白の指摘では名前を出していません。**

1. 数字で見る今回

測定項目	結果
第一報 → 最初の反応	**約2分**
第一報 → ISMS管理者に届くまで	**約10分**
「疑い」として調査・顧客連絡が決まるまで	約16分
CS → エンジニアへ調査依頼	17分
原因の特定（不具合の所在・発生期間）	29分
修正リリース完了（止血）	**48分**
社内対応用チャンネルの作成	**作られなかった**（既存3チャンネルに分散）
ハドル・通話の発生	**なし**（全編テキストのみ）
実システムへの接触	**なし**（ルールどおり）

初動は速く、**1時間以内に原因特定から修正リリースまで到達しています。**

2. よくできていたこと

初動が速い

第一報から**2分**で一次受けが反応し、**10分**で責任者へエスカレーションされました。
「確認します」で止めず、同時に社内へ展開できています。

止血が早い

「まずは出血を止めるのが最優先」という提起（武藤さん）から、**8分で修正リリース**まで
到達しました。調査と並行して修正を進める判断ができています。

影響範囲を自力で掘り下げた

誘導なしで、次の2段階に到達しました。

気づき	誰が
「同じ期間にダウンロードした5社とは何か。優先的に確認すべきでは」	宇野さん
「5社に加えて、その5社に自社情報を見られた可能性のある顧客も影響範囲」	武藤さん

後者は今回いちばん難しい論点です。**漏えいは「受け取った側」だけでなく
「見られた側」にも及ぶ**という構造に、短時間で到達しています。

対外対応の準備が自発的に始まった

依頼を待たずに、顧客周知メールの下書き（吉田さん）、影響顧客の確認シート（宇野さん）、
混入チェック用のスキル（宇野さん）が作られました。CS側の動き出しは速かったです。

ルールが守られた

- 顧客との共有チャンネルに社内の会話が流れたのは**1回のみ**。注意後は発生せず
- **実システムには誰も触っていません。**「確認してみます」という発言は出ましたが、
  ルールがあったため実行には至りませんでした

---

3. 見つかった空白

ここからが今回の成果です。**すべて「決まっていなかったこと」です。**

① 情報が3つのチャンネルに分散した

社内対応用のチャンネルは作られず、やり取りは**個人のtimes → CS-engineer → CSチャンネル**の
3か所、5スレッドに分かれました。終了後、**対応スレッドの一覧を作り直す作業**が発生しています。

なぜ問題か
全体像を持っている人がいなくなる。二重連絡や、回答の食い違いが起きる
あとから時系列を再構成できない。「知った時」の説明が、散らばった履歴の寄せ集めになる
必要な人が入らない／関係ない人を巻き込む

フローに書くこと: 第一報を受けた人が専用チャンネルをその場で立てる（許可を待たない）。
命名規則と、そこに何を集約するか。

② 証跡保全の指示が、誰からも出なかった

今回は修正を優先したため問題になりませんでしたが、実際には
「いつ・誰が・何をダウンロードしたか」のログが、影響範囲を確定する唯一の根拠になります。

調査のために本番を触れば、その操作自体もログに残ります。保全の指示が出ないまま調査が進むと、
根拠を求められた段階で出せるものがないという状態になります。

フローに書くこと: 何を保全するか（ダウンロード操作ログ・デプロイ記録・変更履歴）、
誰が指示するか、触る前に何を宣言するか。

③ 混入元の3社への連絡方針が決まらなかった

全社への周知メールと、CSVをダウンロードした5社への個別報告までは決まりました。
一方、**データの持ち主である3社への通知**は議題に上がらないまま時間切れとなっています。

ここは**報告義務を誰が負うかに直結**します。当社が3社から個人データの取扱いの委託を
受けている立場なら、3社への通知で当社の報告義務が免除され得ます。自ら取得した
個人情報という整理なら、当社が報告主体です。

フローに書くこと: 委託／自社取得の契約上の整理を、どこを見れば分かるようにするか。
「どの顧客との契約が、どちらの類型か」の一覧。

④ 機能を止める判断の権限が決まっていない

今回は修正が数分で完了したため停止は不要でした。ただし、**修正に時間がかかる場合、
不具合のある機能を一時的に止めるかどうか**は誰かが決めなければなりません。
その権限者が決まっていないため、今回は論点として浮上しませんでした。

フローに書くこと: 機能の一時停止を誰が決めるか。深夜・休日はどうするか。

⑤ 「個人情報に当たるか」の判断に幅があった

投票では **1（報告対象）が9名、2（対象外）が1名、3（判断できない）が1名**に割れました。
終了後の質疑でも「氏名以外の項目はどう扱うのか」「ユーザーID＋企業名は個人情報か」という
論点が続いています。

これは認識不足ではなく、**拠り所になる資料が社内に無い**ということです。

フローに書くこと: 当社が扱うデータの各項目について、個人情報に当たるかの整理。
特に**カスタムクエリ**は顧客が任意に値を入れる列であり、中身を把握していないと
漏えいした項目を当社が確定できません。

⑥ 顧客への連絡文面の型が無い

「今までは機能が使えないベースの障害報告だった。個人情報の漏えいになると、
いつものトーンでいいのか悩ましい」という発言がありました。

フローに書くこと: 第一報・続報・最終報告のテンプレート。誰が文面を承認するか。

⑦ 全編テキストのみで進んだ

会議は主催側から立てず、参加者からも立ちませんでした。記録の観点では理想的で、
判断の過程がほぼ全部 Slack に残っています（この報告書も、そのおかげで復元できました）。

一方、認識合わせが必要な論点ほど往復が増えます。実際に、影響範囲の確定と報告主体の判断は
時間内に収束しませんでした。

フローに書くこと: どの時点で音声に切り替えるか（例: 判断が割れたら、30分で収束しなければ）。
音声で決めたことを書き戻すルール。

⑧ エンジニアの対応が1名に集中した

調査の依頼は**エンジニア2名宛**に出されましたが、応答・原因特定・修正リリースまで、
実際に動いたのは**1名**でした。もう1名が入る流れにはなっていません。

今回のシナリオは「当事者が一人で調べて一人で抱える」ことを論点に含めていました。
その状況が、そのまま再現されたことになります。

なぜ問題か
その人が不在・多忙なら、調査が止まる。 今回の速さは一人の即応に依存していた
原因を作った可能性のある人が、一人で事実を確定することになる。 第三者の確認が入らない
修正と報告を同時に抱えることになり、**どちらかが薄くなる**
「2名宛に依頼した」だけでは2名体制にならない。**役割を分けないと一人に寄る**

フローに書くこと: 調査は2名以上で行う。**事実を出す役と、それを確認する役を分ける。**
誰が2人目を指名するか。1名しか確保できない場合にどうするか。

---

4. これから実施すること

1. 今日出た空白を統合し、**対応フローの目次**にします
2. 各項目に責任者と期限を割り当てます
3. 技術面の点検（集計クエリのプロダクト絞り込みのテスト整備・リリース前チェック・
   ダウンロード操作ログの保全）を、エンジニアチームのタスクとして別途起票します
   - **今回の不具合は架空のものです。**実際に起きた事象ではありません。
   ただし同じことが起こり得る箇所なので、未然の点検として扱います
4. 対応フローのドラフトができたら、**関係者のレビューで確認します**（訓練の再実施はしません）

アンケート（Googleフォーム）の回答も、この目次に反映します。**本日中にご協力ください。**

5. 補足

今回の設定について

設定	理由
進行役（空）は「休暇で不在」	シナリオを知っている人が対応に入ると、他の人の判断が観測できないため。普段この対応に入る人が抜けた状態で回るかを見る目的も兼ねています
ISMS管理者にも事前共有なし	全員を訓練の対象にするため
会議を主催側から立てない	実際のインシデントは通常業務中にSlackで始まるため。通知に気づくか、片手間で初動が回るかは、会議ありの訓練では測れません

最後に

当社は無罰ルールです。 誤送信や誤設定をした本人を責めません。
隠されることのほうが、会社にとって圧倒的に危険だからです。

実際に何かやってしまったときは、隠さず、すぐ言ってください。
早く言うほど被害が小さくなります。それだけです。
